

TASK 1:- VULNERABILITY ASSESSMENT REPORT

CIN:- FIT/APR26/CS7953

EXECUTIVE SUMMARY

This report documents a vulnerability assessment conducted on the live web application. The assessment was performed using industry-standard security tools including Nmap, OWASP ZAP, cURL, Browser Developer Tools, and manual inspection techniques. The objective of this assessment was to identify security misconfigurations, exposed services, missing security headers, and other web security issues that could potentially affect confidentiality, integrity, and availability.

The assessment was conducted using passive and non-intrusive testing methods only. No exploitation or destructive actions were performed during the assessment.

ASSESSMENT SCOPE

- Target URL: <https://lets-chat-delta.vercel.app>
- Assessment Type: Passive Vulnerability Assessment
- Tools Used: Nmap, OWASP ZAP, cURL, Chrome DevTools
- Testing Approach: Reconnaissance, Passive Scanning, Manual Inspection

NMAP SCAN RESULTS

The Nmap scan identified the following exposed ports and services:

Port	State	Service
80/tcp	Open	HTTP
443/tcp	Open	HTTPS

ASSESSMENT SCREENSHOTS:-

```
kali@kali:~$ nmap -sV -sC -p- -u https://lets-chat-delta.vercel.app
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-15 07:46 EDT
Nmap scan report for lets-chat-delta.vercel.app (64.29.17.131)
Host is up (0.0005s latency).
Other addresses for lets-chat-delta.vercel.app (not scanned): 216.198.79.131 64:ff9b::481d:1183 64:ff9b::dbc6:4f83
Host shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  HTTP
443/tcp   open  HTTPS

Nmap done: 1 IP address (1 host up) scanned in 7.55 seconds

kali@kali:~$ curl -I https://lets-chat-delta.vercel.app
HTTP/2 200
accept-ranges: bytes
access-control-allow-origin: *
age: 532789
cache-control: public, max-age=0, must-revalidate
content-disposition: inline
content-type: text/html; charset=utf-8
date: Fri, 15 May 2026 11:46:48 GMT
etag: "527b7a1af95408089f9f0d3aed92"
last-modified: Sat, 09 May 2026 07:46:59 GMT
server: Vercel
strict-transport-security: max-age=63072000; includeSubDomains; preload
x-vercel-cache: HIT
x-vercel-enable-rewrite-caching: 1
x-vercel-id: bom1::21jR-1778845688540-6041eae0f469
content-length: 959
```

Figure 1: Nmap Scan Output

```
kali@kali:~$ curl -v https://lets-chat-delta.vercel.app
* Host lets-chat-delta.vercel.app:443 was resolved.
* IPv6: 64:ff9b::dbc6:4f83, 64:ff9b::481d:1183
* IPv4: 216.198.79.131, 64.29.17.131
* Trying [64:ff9b::dbc6:4f83]:443...
* ALPN: curl offers h2,http/1.1
* TLSv1.3 (OUT), TLS handshake, Client hello (1):
* SSL Trust Anchors:
* CAfile: /etc/ssl/certs/ca-certificates.crt
* Ciphers: /etc/ssl/certs
* TLSv1.3 (IN), TLS handshake, Server hello (2):
* TLSv1.3 (IN), TLS change cipher, Change cipher spec (1):
* TLSv1.3 (IN), TLS handshake, Encrypted Extensions (8):
* TLSv1.3 (IN), TLS handshake, Certificate (11):
* TLSv1.3 (IN), TLS handshake, CERT verify (15):
* TLSv1.3 (IN), TLS handshake, Finished (20):
* TLSv1.3 (OUT), TLS change cipher, Change cipher spec (1):
* TLSv1.3 (OUT), TLS handshake, Finished (20):
* SSL connection using TLSv1.3 / TLS_AES_128_GCM_SHA256 / X25519MLKEM768 / RSASSA-PSS
* ALPN: server accepted h2
* Server certificate:
* subject: CN=*.vercel.app
* start date: Apr 28 02:04:43 2026 GMT
* expire date: Jul 27 02:04:42 2026 GMT
* issuer: CN=DigiNotar Trust Services, CN=WR1
* Certificate level 0: Public key type RSA (2048/112 Bits/secBits), signed using sha256WithRSAEncryption
```

Figure 2: cURL SSL/TLS Verification

```
Session Actions Edit View Help
* TLSv1.3 (IN), TLS change cipher, Change cipher spec (1):
* TLSv1.3 (IN), TLS handshake, Encrypted Extensions (8):
* TLSv1.3 (IN), TLS handshake, Certificate (11):
* TLSv1.3 (IN), TLS handshake, CERT verify (15):
* TLSv1.3 (IN), TLS handshake, Finished (20):
* TLSv1.3 (OUT), TLS change cipher, Change cipher spec (1):
* TLSv1.3 (OUT), TLS handshake, Finished (20):
* SSL connection using TLSv1.3 / TLS_AES_128_GCM_SHA256 / X25519MLKEM768 / RSASSA-PSS
* ALPN: server accepted h2
* Server certificate:
* subject: CN=*.vercel.app
* start date: Apr 28 02:04:43 2026 GMT
* expire date: Jul 27 02:04:42 2026 GMT
* issuer: CN=DigiNotar Trust Services, CN=WR1
* Certificate level 0: Public key type RSA (2048/112 Bits/secBits), signed using sha256WithRSAEncryption
* Certificate level 1: Public key type RSA (2048/112 Bits/secBits), signed using sha256WithRSAEncryption
* Certificate level 2: Public key type RSA (4096/152 Bits/secBits), signed using sha384WithRSAEncryption
* subjectAltName: 'lets-chat-delta.vercel.app' matches cert's '*.vercel.app'
* SSL certificate verified via OpenSSL
* Established connection to lets-chat-delta.vercel.app (64:ff9b::dbc6:4f83 port 443) from fd17:625c:f837:2:ebc5:1ec4:95a9:3a03 port 51130
* using HTTP/2
* [HTTP/2] [1] OPENED stream for https://lets-chat-delta.vercel.app/
* [HTTP/2] [1] [method: GET]
* [HTTP/2] [1] [scheme: https]
* [HTTP/2] [1] [authority: lets-chat-delta.vercel.app]
* [HTTP/2] [1] [path: /]
* [HTTP/2] [1] [user-agent: curl/8.17.0]
* [HTTP/2] [1] [accept: */*]
* GET / HTTP/2
* Host: lets-chat-delta.vercel.app
* User-Agent: curl/8.17.0
* Accept: */*

* TLSv1.3 (IN), TLS handshake, NewSession Ticket (4):
* Request completely sent off
< HTTP/2 200
< accept-ranges: bytes
< access-control-allow-origin: *
< age: 532985
< cache-control: public, max-age=0, must-revalidate
< content-disposition: inline
< content-type: text/html; charset=utf-8
< date: Fri, 15 May 2026 11:58:04 GMT
< etag: "527b7a1af95408089f9f0d3aed92"
< last-modified: Sat, 09 May 2026 07:46:59 GMT
< server: Vercel
< strict-transport-security: max-age=63072000; includeSubDomains; preload
< x-vercel-cache: HIT
< x-vercel-enable-rewrite-caching: 1
< x-vercel-id: bom1::sshb-1778845804178-1dd576c57821
< content-length: 959

* Connection #0 to host lets-chat-delta.vercel.app:443 left intact
<doctype html><html lang=en><head><meta charset=utf-8><link rel=icon href=/favicon.ico><meta name=viewport content=width=device-width,initial-scale=1><meta name=theme-color content=#000000><meta name=description content=Chat app using React, Firebase, MongoDB, Express and Socket.io><meta name=Keyword content=Chat app,mern stack, socket.io, firebase><link rel=apple-touch-icon sizes=180x180 href=/apple-touch-icon.png><link rel=ico icon type=image/png sizes=16x16 href=/favicon-16x16.png><link rel=manifest href=/site.webmanifest><link rel=manifest href=/manifest.json><title>lets Chat</title><script defer=defer src=/static/js/main.837158d2.js></script><link href=/static/css/main.d0f456dd.css rel=stylesheet></head><body><noscript>You need to enable JavaScript to run this app.</noscript><div id=root></div></body></html>
```

Figure 3: Browser Developer Tools Network Analysis

RECOMMENDATIONS

- Implement a strong Content Security Policy (CSP).
- Add all recommended HTTP security headers.
- Enable secure cookie flags including HttpOnly and Secure.
- Regularly perform vulnerability assessments and penetration testing.
- Monitor logs and suspicious activities continuously.
- Apply security hardening and dependency updates regularly.

CONCLUSION

The assessment identified several medium and low-risk vulnerabilities related to security headers and application configuration. While no critical vulnerabilities were exploited during this assessment, implementing the recommended mitigations will significantly improve the overall security posture of the application. Regular assessments, patch management, and secure development practices are strongly recommended.